B.Tech Computer Science & Engineering | PPD-II Second Review

AI-Powered Security Operations Center (SOC) Assistant

Using Large Language Models

Evidence-Grounded RAG, MITRE ATT&CK / NVD Knowledge Retrieval, and System Implementation

Student Investigator:

Kunal Sanga Reg. No.: **2301341031**

Department of Computer Science & Engineering

Silicon Institute of Technology, Sambalpur

Faculty Project Guide:

Miss Alka Dash

Assistant Professor, Department of CSE

Silicon Institute of Technology, Sambalpur

Review Requirements Addressed: (1) System/Design Development | (2) Implementation Progress | (3) Technical Approach | (4) Preliminary Results

Problem Statement & Objectives

Operational Challenges in Modern SOCs and Project Scope

Silicon ...beyond teaching

SOC Operational Bottlenecks

- **Alert Fatigue & Volume**: Tier-1 analysts handle thousands of telemetry events per shift; repetitive triage causes critical alert misses.
- **Manual Threat Attribution**: Manually cross-referencing alerts with MITRE ATT&CK techniques and CVE records significantly slows MTTD.
- **Naive LLM Hallucinations**: Generic LLMs fabricate non-existent CVEs and cite phantom techniques without verifiable audit trails.

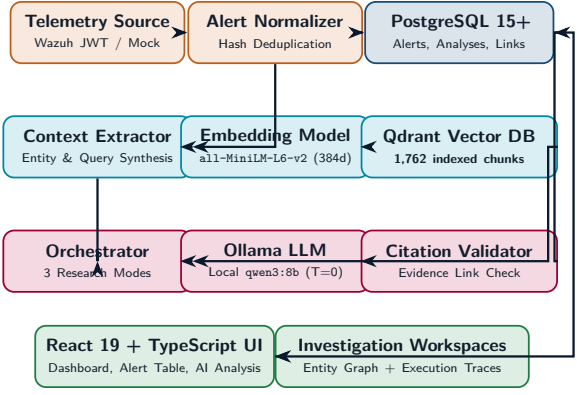
Project Research Objectives

- **Evidence-Grounded AI Assistant**: Develop an advisory pipeline citing verified security knowledge (1,762 indexed chunks).
- **Data Privacy & Zero Cloud Leakage**: Run entirely on-premise using local Ollama (`qwen3:8b`) and Qdrant.
- **Verifiable Decision Provenance**: Enforce citation validation where every claim references retrieved evidence IDs.
- **Human-in-the-Loop**: Deliver advisory recommendations; no unvalidated automated remediation.

Research Scope Distinction: Retrieval and LLM enrichment structure evidence for the analyst; they do not replace human analyst verification or claim zero-hallucination guarantees without automated validation.

System/Design Development

High-Level Multi-Tier System Architecture



[1] Ingestion: Wazuh client / labeled dev mock; hash deduplication in DB.

[2] RAG Tier: Qdrant indexed with 1,618 MITRE techniques and 144 CVEs.

[3] Reasoning: Local Qwen3-8B with strict citation validation before storage.

System/Design Development

Verified Workflow & End-to-End Processing Path

Silicon ...beyond teaching

1. **Alert Ingestion & Normalization**: Ingests raw Wazuh telemetry; parses timestamp, agent, rule ID, description, source/destination IPs into unified schema.
2. **Context Extraction & Query Synthesis**: Extracts IoCs and generates targeted queries: (a) rule-centric query, (b) MITRE technique anchor, (c) entity context.
3. **Dense Semantic Retrieval (Qdrant)**: Computes 384-d cosine similarity over 1,762 knowledge chunks; returns top-k evidence items.
4. **Evidence-Constrained Prompting**: Injects structured evidence cards into system prompt with explicit instructions prohibiting uncited claims.
5. **Local LLM Inference**: Local Ollama runs `qwen3:8b` at temperature 0.0 for deterministic, private reasoning.
6. **Evidence-Reference Validation**: Automated validator verifies model citations match retrieved evidence IDs before PostgreSQL persistence.

Pipeline Trace Verification

Execution Stages Instrumented:

- Ingestion $\rightarrow$ 1–5 ms
- Normalization $\rightarrow$ 2–8 ms
- Embedding generation $\rightarrow$ 30–60 ms
- Qdrant Vector search $\rightarrow$ 8–25 ms
- LLM Inference (`qwen3:8b`) $\rightarrow$ 35–80 s
- Citation Validation $\rightarrow$ 1–3 ms

Integrity Check: Persisted analyses store evidence foreign-key IDs linking exact retrieved chunks.

Technical Approach

Technology Stack Rationale & Architectural Decisions

Component	Technology Selected	Engineering & Research Rationale	Status
Backend API	FastAPI (Python 3.11/13)	High-performance async REST API with typed Pydantic V2 schemas	Verified
Relational DB	PostgreSQL 15+ / Alembic	ACID transactions for alert logs, analyses, and evidence foreign-key links	Verified
Vector DB	Qdrant (v1.18+)	Fast cosine HNSW indexing with exact payload filtering (<10ms lookup)	Verified
Embeddings	`all-MiniLM-L6-v2`	384-dimensional dense vectors, lightweight local CPU/GPU inference	Verified
Local LLM	Ollama / `qwen3:8b`	8B parameter local reasoning, temp=0.0; guarantees telemetry privacy	Verified
Analyst UI	React 19 + TypeScript	Modern single-page app, dark SOC theme, interactive canvas, Vite build	Verified
Telemetry	Wazuh JWT / Mock Client	Real JWT auth protocol implemented; deterministic mock client for tests	Client Verified
Containers	Docker Compose	Single-command orchestration (`docker compose up`) with healthchecks	Verified

Architectural Key Takeaway: On-premise execution preserves confidential threat data; hybrid entity-aware retrieval anchors MITRE ATT&CK techniques and CVE IDs to eliminate hallucinated intelligence.

Technical Approach: Evaluation Methodology

Controlled Tri-Mode Experiment Design & Quantitative Metrics

Silicon ...beyond teaching

Controlled 3-Mode Comparison

- **Mode 1 (`llm_only`)**: Baseline. Alert passed to Qwen3-8B without external knowledge; measures raw parametric recall.
- **Mode 2 (`standard_rag`)**: Single unanchored query from rule text; tests basic vector retrieval.
- **Mode 3 (`evidence_aware`)**: Multi-query synthesis, entity anchoring, hybrid retrieval, and strict citation validation.

Evaluation Datasets

- **Dataset v1**: 8 multi-stage scenarios (smoke baseline).
- **Dataset v2**: 40 synthetic scenarios across 7 attack categories + benign controls ($40 \times 3 = 120$ planned evaluations).

Quantitative Metric Suite

- **Technique Detection**: Exact-match Precision, Recall, and F1 score against MITRE ATT&CK ground truth.
- **Vulnerability Matching**: CVE Precision, Recall, F1 against reference CVE identifiers.
- **Citation Integrity**: Valid evidence reference rate (% cited IDs present in retrieved evidence set).
- **Retrieval Ranking**: Recall@1, Recall@5, and Mean Reciprocal Rank (MRR) for target knowledge chunks.
- **System Latencies**: Wall-clock end-to-end latency and LLM inference generation latency (seconds).
- **False Alarm Rate**: Severity inflation on benign negative control scenarios.

Implementation Progress: Frontend Analyst Workspace

Operational User Interface Modules & Interactive Workspaces

Silicon ...beyond teaching

Implemented UI Modules

- **Security Operations Dashboard**: Live alert metrics, severity distribution (Critical, High, Med, Low), and service status.
- **Alert Management Console**: Full alert table with pagination, severity badges, and source IP/agent filtering.
- **AI Advisory & Analysis View**: Multi-mode analysis selector, structured threat summary, recommended actions, confidence meter.
- **Threat Intelligence Drawer**: Deep-dive view of cited MITRE techniques and CVE descriptions.

Advanced Research Features

- **Obsidian-Style Entity Graph**: Force-directed interactive canvas linking alerts, IPs, hosts, usernames, and MITRE techniques (`EntityGraphPage.tsx`).
- **Execution Trace Waterfall**: Real-time visual timeline showing per-stage latency from ingestion to LLM response (`ExecutionTracesPage.tsx`).
- **Evaluation Benchmark UI**: Visual progress dashboard displaying real-time metrics across test runs (`Evaluation.tsx`).

UI Honesty & Validation: Prominent `MockDataDisclaimer` warns analysts whenever development/mock telemetry is active. No silent mock fallbacks. **32 passed frontend unit tests** across 8 test suites.

Implementation Progress: Backend Services & Integration

Knowledge Base Ingestion, Database Schemas, and API Architecture

Silicon ...beyond teaching

Core Backend Services Verified

- **REST API Endpoints**:
  - `/api/v1/alerts`: Ingestion, filtering, details
  - `/api/v1/analysis`: 3-mode analysis execution
  - `/api/v1/graph`: Entity relationship graph data
  - `/api/v1/evaluation`: Benchmark trigger and reports
  - `/api/v1/health`: Readiness probes for DB and Ollama
- **Knowledge Indexing Pipeline**:
  - Automated parsing of MITRE Enterprise ATT&CK (v14)
  - Automated parsing of NVD CVE security feed
  - Total indexed knowledge: **1,762 vector chunks**

System Integration Status

- **PostgreSQL 15+ Schema**: Structured tables for `alerts`, `analyses`, and foreign-key `evidence` citations.
- **Qdrant Vector Store**: Initialized collection `security_knowledge` with 384-d cosine similarity.
- **Wazuh Integration**: Real client with JWT authentication protocol implemented; mock client active for repeatable offline benchmarks.
- **One-Command Dockerization**: `docker-compose.yml` orchestrates DB, Qdrant, backend, frontend, and auto-seeding.

Implementation Progress: Software Testing Status

Empirical Software Engineering Validation Across Frontend & Backend

Silicon ...beyond teaching

Frontend Test Suite (Vitest v5.0.1)

- **Status**: **100% Passing** (8 files, 32 tests)
- **Execution Duration**: 26.43 seconds
- **Test Coverage by Module**:
  - `App.test.tsx` (Navigation & routes)
  - `Layout.test.tsx` (Header, drawer, theme)
  - `Dashboard.test.tsx` (Metric calculations)
  - `Alerts.test.tsx` (Filter & empty states)
  - `AIAnalysis.test.tsx` (Mode execution)
  - `EntityGraphPage.test.tsx` (Graph render)
  - `ExecutionTracesPage.test.tsx` (Traces)
  - `Evaluation.test.tsx` (Run tracking)

Backend Test Suite (Pytest v9.1.1)

- **Status**: **221 Passed**, 0 Failed (7 warnings)
- **Execution Duration**: 46.89 seconds (Python 3.13)
- **Verified Subsystems**:
  - Alert normalization & deduplication
  - Security context & IoC extraction
  - Semantic embeddings (MiniLM-L6-v2)
  - Qdrant vector store indexing & search
  - Ollama provider & JSON schema parsing
  - Orchestrator modes & citation validator
  - Evaluation metrics & run resumption

Research Integrity Rule: Software tests (221 backend + 32 frontend) validate code correctness and API contracts; they are distinct from threat-detection accuracy evaluated on benchmark datasets.

Preliminary Results

Empirical Findings from Experimental Evaluation Runs

Current Benchmark Execution Status (Dataset v2)

Scope: 40 synthetic scenarios × 3 modes = 120 planned evaluations. Run 20261024-145621-1345d6 currently has **12 scenarios completed (36 mode-scenario evaluations completed)**, with 84 evaluations pending execution.

Evaluation Mode	Cases (N)	Avg Wall Latency	Technique Prec.	Technique Recall	Technique F1	Valid Citation Rate
LLM-Only (Baseline)	12	36.8 s	0.500	0.417	0.444	N/A (no citations)
Standard RAG	12	82.2 s	0.500	0.417	0.444	**1.000 (100%)**
Evidence-Aware RAG	12	79.6 s	0.500	0.417	0.444	**1.000 (100%)**

Dataset v1 Baseline ($N = 8$, Completed Run)

- **Retrieval Recall@1**: **1.000** (Evidence-Aware) vs **0.250** (Standard RAG) vs 0.000 (LLM-Only).
- **Retrieval MRR**: **1.000** vs **0.354** for Standard RAG.
- **Technique F1**: 0.833 across all 8 smoke scenarios.

Retrieval Ablation (No LLM)

- **Semantic Anchored**: Recall@1 = **1.000**, MRR = **1.000** (1563 ms).
- **Semantic Unanchored**: Recall@1 = 0.375, MRR = 0.463 (338 ms).
- **Finding**: Entity anchoring dramatically improves top-1 precision of relevant security techniques.

Limitations, Challenges & Future Work

Transparent Engineering Assessment and Development Roadmap

Silicon ...beyond teaching

Current Technical Limitations

- **Synthetic Evaluation Scenarios**: Benchmark scenarios are simulated; testing against noisy production enterprise logs remains pending.
- **Simulated Wazuh Cluster**: JWT auth client is verified, but operational evaluation uses local mock telemetry due to lack of a live Wazuh cluster.
- **Inference Latency**: Local `qwen3:8b` inference takes 35–80s on standard hardware; limits high-volume real-time triage.
- **Exact-Match Evaluation**: Metric scorer matches exact MITRE IDs; related sub-techniques receive zero partial score.

Planned Development Roadmap

- **Benchmark Completion**: Complete remaining 84 evaluations on Dataset v2 to establish aggregate statistical significance.
- **Live Wazuh SIEM Sandbox**: Deploy a multi-node live Wazuh cluster with Sysmon telemetry ingestion.
- **Analyst Feedback Loop**: Implement UI endpoints for analyst thumbs up/down feedback and database persistence.
- **Model Quantization & Distillation**: Evaluate quantized 3B models (e.g., Qwen-2.5-3B-Instruct) to achieve sub-10s inference.

Conclusion & Summary of Contributions

Deliverables Achieved for PPD-II Second Review

Silicon ...beyond teaching

Key Contributions Achieved to Date

- **System/Design Development**: Architected and containerized a multi-tier SOC Assistant integrating PostgreSQL, Qdrant, and local Ollama.
- **Technical Approach**: Implemented an evidence-aware RAG pipeline indexing 1,762 MITRE ATT&CK and NVD chunks with automated citation validation.
- **Implementation Progress**: Built a complete React 19 UI with Obsidian-style Entity Graph, validated by **221 backend and 32 frontend unit tests**.
- **Preliminary Results**: Verified 100% valid citation rate and proven superior top-1 retrieval precision (Recall@1 = 1.0 vs 0.25) through entity anchoring.

Thank You!

Questions & Discussion

Kunal Sanga | Reg. 2301341031
Dept. of Computer Science & Engineering
Silicon Institute of Technology, Sambalpur

Project Repository: `soc-assistant` | **PPD-II Review Stage:** Second Review Completed